

Updated: 08/23/2005
Version: 1.0 RC 2

Hypermedia Systems, Inc.
601 S. Figueroa St., 43rd Floor
Los Angeles, CA. 90017

Table of Contents

Table of Contents.....	2
1 Introduction.....	3
2 Scope, methodologies and limitations.....	3
2.1 Scope.....	3
2.2 Methodologies.....	3
2.3 Limitations.....	4
3 Application description	4
3.1 Functionality.....	4
3.2 Initial Setup and configuration.....	5
4 TODO:.....	6
4.1 Implement notification method.....	6

1 Introduction

The Enterprise Security Team is looking into several ways to implement input validation for all systems. As it is well understood the web is very susceptible to attacks. One way to protect against some types of attacks is through using Intrusion Detection Systems. Snort from www.snort.org provides software that protects systems using IDS methods. Snort works by having a set of signatures and applies them to incoming network traffic.

Zeus has adopted some of that functionality by using snort rule sets that apply to the web and incorporates them into their web server software. Our team is looking into how HMS can take advantage of that technology and incorporate it into all Zeus web servers.

In the following sections we will attempt to explain the benefits of adopting this technology, its limitations, and implementation details. We will also examine our current web server vulnerabilities and what types of vulnerabilities would be mitigated by using zeus-snort rule sets.

2 Scope, methodologies and limitations

2.1 Scope

The implementation of this technology adds an extra layer of protection to our infrastructure. This technology is designed to handle validation of HTTP requests only. A great number of attacks happen through HTTP requests. The effectiveness of this system is only as good as the rule sets that are used, and that is where the main problem appears to be.

Our challenge is to determine which rules are useful, which are not, and which although may be useful would cause issues such as Denial of Service to clients. Currently the rule set used by zeus-snort are quite generic and some rules apply to particular web servers such as apache or IIS. On the other hand, there are some rules that were not in the original rule set but were found to be quite necessary to include.

2.2 Methodologies

Zeus implements HTTP request validation using regular expressions functions from glibc's library thus it is very fast. In our previous tests the performance decrease was negligible with a rule set of 231.

2.3 Limitations

As mentioned above the performance decrease is negligible, therefore we can implement very large rule sets or signatures. However, for this first phase we would like to “play safe” and only implement the most recommended rule sets to observe its operation and logs. This is in order to gain knowledge and fine tune the rule sets.

3 Application description

3.1 Functionality

The main purpose of this IDS system is to drop “bad” HTTP requests. As mentioned above this is achieved through regular expressions contained in a list which we have named rule set. We have taken the original rule set and done the following:

- Deleted rules that were considered unnecessary. Rules specific to other web servers, non unix/linux os dependent, redundant rules.
- Consolidated several rules into one.
- Created new rules that we considered quite essential and address specific issues that the original rule set fails to address.

When the rules are loaded and enabled in a Zeus web server if the server gets a request that matches either the regular expression or a particular key word it will just drop the connection.

3.2 Initial Setup and configuration

We had been working with Zeus technical support personnel and we found out that it does not properly handle percent symbol encoding translation. They have fixed that issue and provided a patch for it. In order for the rule sets to protect properly we must first install this patch. They provided a zeus.web file that must be copied to:

```
/usr/local/zeus/web/bin/zeus.web
```

Make sure, you back up the original one, just in case, and adjust the path given above if applicable.

Make sure the permissions on the patch file are correct. They should be something like:

```
-rwxr-xr-x 1 root sys 2.2M Aug 17 09:46 zeus.web*
```

Restart the Zeus web server.

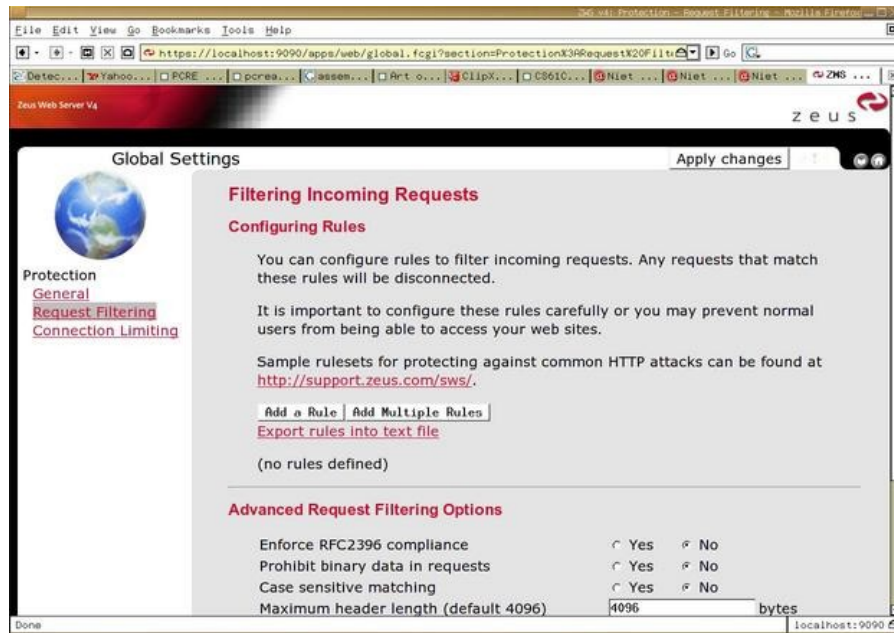
Once we have the patch installed and the rule set we want, we are ready to load them into the zeus web server. This is typically done through the global configuration zeus administration interface. For details, you can consult the zeus web server manual, but it is really simple. Here are the steps:

- Enter the zeus web server admin interface
- Click the link to enter 'Global Configuration'



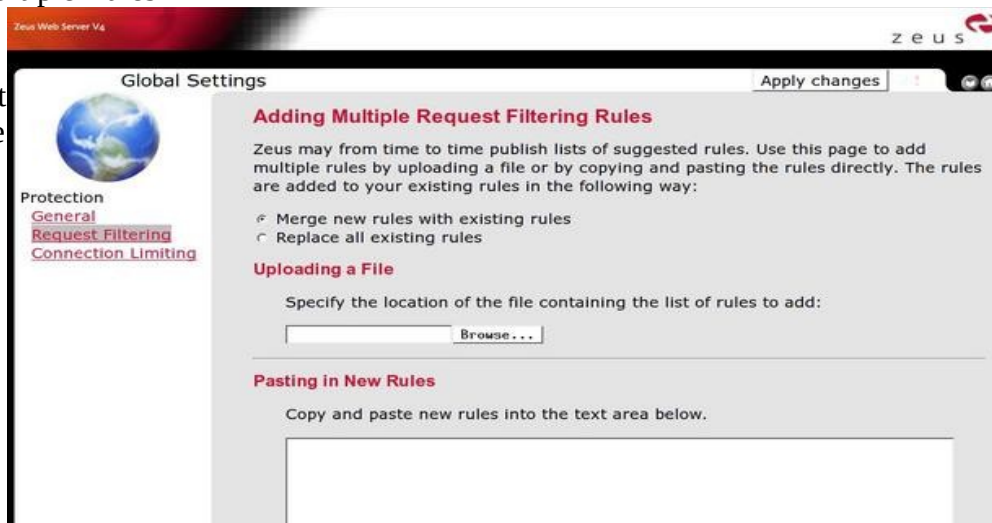
- Click on 'Request Filtering' on the left panel

- Click on 'Add



Multiple Rules'

- Select the



option to merge or replace accordingly. Normally you want to merge

- Click on the browse button to upload the rules set file
- Click on 'Apply Changes'
- Click on the link [“This configuration has been modified. Click here for details or to make it take effect.”](#)
- Click yet one more time on the commit changes button
- Restart the web server

Note: In order for this to work, please make sure that you enable protection. This is done also in the global configuration, in the General section.

